

授权漏洞扫描自查与报告模板包

适用对象：准备给自己的网站、小程序后台、SaaS 管理端、企业官网、内部系统做上线前安全自查的人；也适合接单方在开始漏洞扫描、轻量安全巡检、整改复测前统一口径。

边界声明：本材料只用于自有资产或已获得书面授权的目标。不得用于未经授权网站、账号撞库、绕过登录、批量探测第三方资产、利用漏洞获取数据、传播攻击 payload、规避风控或破坏服务。

1. 商品差异点

市面上常见资料多是“工具路线图”“漏洞赏金入门”或“端口扫描接口”。本包不教攻击利用，重点解决交付前后最容易出纠纷的三件事：

1. 扫描前如何确认授权范围，避免越界。
2. 扫描中如何记录证据、分级、复测，避免报告空泛。
3. 扫描后如何把问题转成开发能执行的整改单。

交付结果是一套可复制的工作模板，不依赖某个扫描工具，也不会要求买家提供账号密码给陌生人。

2. 扫描前授权确认单

项目名称：

甲方联系人：

乙方执行人：

授权日期：

授权有效期：

允许测试的资产：

- 域名：
- IP 或网段：
- 后台路径：
- 测试账号：
- 测试环境：
- 生产环境限制：

明确禁止的行为：

- 禁止对未列入范围的域名、IP、子域、供应商系统进行测试。
- 禁止高并发压测、拒绝服务测试、爆破、撞库、社工、钓鱼。
- 禁止读取、导出、修改、删除非必要业务数据。
- 禁止上传 WebShell、后门、挖矿程序或持久化代码。
- 禁止绕过支付、风控、身份验证后进行真实交易。

可接受的验证方式：

- 截图证明。
- 响应头、状态码、版本号、配置证据。
- 最小化复现步骤。
- 脱敏后的请求和响应摘要。

- 修复后复测截图。

3. 轻量漏洞扫描检查清单

A. 资产与暴露面

检查目标：

- 主域名、子域名、管理后台、API 网关、静态资源域名是否列入授权。
- 是否存在默认测试页面、旧版本后台、临时目录、未清理部署包。
- 是否存在公开的调试接口、健康检查接口、Swagger/OpenAPI 文档。

记录字段：

- 资产地址
- 发现方式
- 是否授权
- 风险说明
- 建议动作

整改建议：

- 下线无业务价值的临时入口。
- 对后台和调试接口加访问控制。
- 公开文档只保留必要字段，不暴露内部地址、密钥格式、测试账号。

B. HTTP 安全响应头

检查目标：

- Strict-Transport-Security
- Content-Security-Policy
- X-Frame-Options 或 frame-ancestors
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy
- Cookie 的 Secure、HttpOnly、SameSite

报告写法：

- 问题：缺少关键安全响应头，浏览器侧防护不足。
- 影响：可能增加点击劫持、内容嗅探、跨站脚本影响面或 Cookie 泄露风险。
- 证据：记录目标 URL、响应头快照、检测时间。
- 建议：按业务兼容性逐步补齐，先在测试环境验证，再灰度生产。

C. 认证与会话

检查目标：

- 登录失败提示是否泄露账号是否存在。
- 密码重置链接是否一次性、短时效。
- 会话 Cookie 是否具备 Secure、HttpOnly、SameSite。
- 退出登录后旧会话是否失效。

- 管理员功能是否做服务端权限校验。

不做内容：

- 不做撞库。
- 不做密码爆破。
- 不绕过验证码。
- 不测试真实用户账号。

D. 输入输出与常见 Web 风险

检查目标：

- 查询、搜索、评论、上传、导入、回调地址等输入点是否有服务端校验。
- 页面输出是否做上下文转义。
- 文件上传是否限制类型、大小、存储路径和访问权限。
- API 是否对业务对象做权限校验。

报告写法：

- 只写风险类别、触发条件、影响范围和修复建议。
- 不在报告正文公开可直接复制攻击的完整 payload。
- 如必须提交复现证据，单独放在受控附件，并确认接收人权限。

E. 依赖与配置

检查目标：

- package-lock、requirements、pom、go.mod、Dockerfile、镜像基础版本。
- 是否存在已公开高危漏洞版本。
- 是否存在默认密钥、示例密钥、调试模式、过宽 CORS。
- 是否将 .env、备份包、日志包暴露到 Web 目录。

整改建议：

- 固定依赖版本并定期更新。
- 生产环境关闭 debug。
- 密钥进入专用密钥管理或环境变量，不入库。
- 备份文件放到非 Web 可访问路径。

4. 风险分级标准

严重：

- 可未经授权读取、修改、删除敏感数据。
- 可获取管理员权限或服务端执行能力。
- 可绕过支付、订单、资金、身份校验。
- 可导致生产服务大面积不可用。

高：

- 可越权访问他人资源。
- 可稳定触发账号接管链路。
- 可读取敏感配置、密钥、日志。
- 可造成大范围业务数据泄露。

中：

- 安全响应头缺失并存在可利用场景。
- 信息泄露可辅助进一步攻击。
- 业务校验不完整但需要较强前置条件。

低：

- 暴露版本信息。
- 错误页信息过多。
- 个别配置不符合最佳实践但暂无直接影响。

信息：

- 规范建议、加固建议、流程建议、文档建议。

5. 漏洞报告模板

标题：

风险等级：

影响资产：

发现时间：

授权范围编号：

问题概述：

影响说明：

复现条件：

最小化证据：

受影响用户或数据范围：

修复建议：

临时缓解方案：

复测步骤：

复测结果：

关闭条件：

6. 整改工单模板

工单标题：

负责人：

期望完成时间：

关联漏洞编号：

受影响模块：

必须完成：

- 修复服务端校验。
- 补充自动化测试。
- 更新配置或依赖。
- 验证生产灰度结果。

验收标准：

- 未授权用户无法访问目标资源。
- 旧会话、旧链接、旧参数无法复用。
- 日志中无敏感明文。
- 复测截图与请求摘要已归档。

7. 7 天执行计划

第 1 天：确认授权范围，整理资产清单，冻结测试窗口。

第 2 天：检查公开暴露面、后台入口、调试接口、文档接口。

第 3 天：检查 HTTP 安全头、Cookie、CORS、错误页、缓存策略。

第 4 天：检查认证、会话、密码重置、权限边界。

第 5 天：检查输入输出、上传导入、业务对象权限。

第 6 天：检查依赖、配置、备份文件、日志和密钥痕迹。

第 7 天：整理报告、分级、整改工单、复测计划。

8. 对外服务上架文案

标题备选：

- 授权网站漏洞扫描自查与整改报告
- Web 安全头与权限边界轻量巡检
- 上线前安全自查报告与复测清单
- 小团队网站安全加固检查包

服务描述：

为自有或已授权的网站、后台、API 做轻量安全自查，输出资产范围、风险清单、整改建议、复测记录和开发可执行工单。服务不包含未授权扫描、爆破、撞库、漏洞利用、数据读取、绕过支付或破坏性测试。

买家需提供：

- 授权目标。
- 测试窗口。
- 测试账号。
- 联系人。
- 是否允许访问生产环境。
- 是否有历史报告。

交付物：

- 安全自查报告。
- 风险分级表。
- 整改工单。
- 复测清单。
- 安全响应头建议。

不接范围：

- 未授权第三方网站。

- SRC 代挖、赏金包过。
- 攻击教学。
- 批量扫描陌生 IP。
- 社工、钓鱼、撞库。
- 绕过验证码、支付、风控。

9. 客户沟通话术

询单回复：

可以做轻量安全自查。先确认一点：目标必须是你自有或已经获得授权的系统。我会按授权范围检查暴露面、安全响应头、登录会话、权限边界、依赖配置，并输出报告和整改清单。

范围确认：

请提供允许检查的域名、后台地址、测试账号、测试时间窗口，以及明确不能碰的范围。我只在授权范围内做验证，不做爆破、绕过和破坏性测试。

交付说明：

交付会包含风险等级、影响说明、证据摘要、修复建议和复测标准。敏感证据会脱敏，避免报告二次泄露。

拒单话术：

这个目标如果不是你自有或没有授权，我不能接。安全测试必须先确认授权范围，否则对双方都有法律和账号风险。

10. 定价建议

轻量模板商品建议价：128 UT。

依据：

- 同类安全扫描路线图和 DevSecOps 资料常见价格约 100 到 168 UT。
- 漏洞赏金类资料价格约 168 UT，但风险更高、同质化更重。
- 本包定位为合规交付模板和整改报告体系，适合接单者直接复用，定价放在中间偏低，利于冷启动。

服务接单价可按范围拆分：

- 单站点安全头和基础配置检查：80 到 150 UT。
- 单站点轻量自查报告：200 到 500 UT。
- 带复测和整改工单：500 到 1200 UT。

以上价格不承诺收益，只用于上架报价参考。

11. 避坑提醒

- 不要写“保证挖到漏洞”“月入过万”“包过 SRC”。
- 不要接未授权目标。
- 不要把扫描工具输出原样当报告。
- 不要在报告里公开完整攻击 payload。
- 不要保存客户账号密码明文。
- 不要把生产数据截图发到公开聊天。
- 不要把“安全扫描”包装成攻击服务。

正确卖点是：合规、可交付、可复测、能让开发照着改。